ChatGPT

Executive Summary

This deliverable set demonstrates a complete end-to-end penetration-testing lab exercise in a **safe, controlled environment**. We assume a closed virtual lab (no Internet) using authorized VMs only. For example, our target is a deliberately vulnerable Metasploitable2 VM (Ubuntu 8.04 with known flaws) and our attacker is Kali Linux (latest version with tools like Nmap, Metasploit). All data used (usernames, passwords, exploits) are **synthetic or dummy**. We never attack real systems or use real credentials【5†L86-L89】【8†L248-L257】. The scope and methodology are clearly documented, and each finding includes commands, screenshots, and remediation steps. Mitigations are drawn from official sources (OWASP, NIST, vendor advisories) to demonstrate best practices. The deliverables include:

- **Written Penetration Test Report** (with executive summary, scope/methodology, findings, evidence, impact, and remediation).
- **GitHub Repository** (with structured folders for the report, scripts, screenshots, and documentation, plus a README and commit history).
- **10-minute Demo Video Script** (with timed narration, on-screen actions, and a recording checklist).

Each deliverable is cross-referenced and reproducible in the offline lab. Timelines and file naming conventions are outlined to guide production. This report provides a **methodical blueprint** for assembling all components of a student's penetration-testing assignment.

Lab Scope and Safe-Lab Assumptions

- **Authorized Lab Only:** Testing is confined to VMs we own and control. We use host-only or NAT networking (never the public Internet)【8†L248-L257】. For example, both Kali and Metasploitable2 are on an internal virtual network.
- **Intentionally Vulnerable Target:** Metasploitable2 is a training VM full of known flaws (FTP, SSH, SMB, Tomcat, etc.)【8†L248-L257】. Its IP (e.g. `192.168.56.101`) is isolated. We never expose it externally.
- **Synthetic Data:** All credentials and payloads are test-only. The password `msfadmin:msfadmin` is default on Metasploitable【5†L86-L89】. Any "harvested" data (e.g. dummy files or logs) are fake and used only for demonstration.
- **Legal/Ethical:** Techniques are demonstrated on our lab machines only. As one source notes, *"All demonstrations…are performed on machines owned by us or intentionally designed to be vulnerable. Never use these techniques on unauthorized systems."*【5†L86-L89】.

Environment Inventory

- **Attacker VM (Kali Linux):** Latest Kali (e.g. 2026.1) with tools: Nmap, Metasploit (`msfconsole`), Burp Suite (for web tests), Hydra, etc. Metasploit comes pre-installed on Kali【5†L108-L113】.
- **Target VM (Metasploitable2):** Ubuntu 8.04 LTS with dozens of vulnerabilities【8†L248-L257】 (FTP backdoor, SSH, Telnet, Samba, web servers, MySQL with weak creds, etc.). We note default credentials `msfadmin/msfadmin` 【5†L160-L166】.

- **Lab Topology:** Both VMs on a private network. Kali's IP might be `192.168.56.102`, Metasploitable2 `192.168.56.101`. No other systems are involved.

```
graph TD
    A[Kali Linux (Attacker)] --- B[Metasploitable2 (Target)]
    B --- C[Optional Proxy / Logging VM]
    click A "https://kali.org" "Kali Linux"
    click B "https://rapid7.com/metasploitable2" "Metasploitable2 VM"
```

Figure: Lab network topology – a private link between the attacker and target VMs (NAT/host-only). All traffic stays within the host machine.

GitHub Repository Structure

A clear folder layout keeps the repo organized. For example:

Path	Type	Description
`README.md`	Markdown	Project overview, prerequisites, lab topology, how to reproduce tests.
`report/penetration_report.docx` (or `.pdf`)	DOCX/PDF	Detailed pentest report (see Template below).
`scripts/`	Directory	Custom exploit scripts or tools (if any).
`evidence/screenshots/`	Directory	Step-by-step screenshots (PNG files) for report.
`evidence/logs/`	Directory	Captured logs or `strace` outputs (TXT).
`demo/`	Directory	Video script and storyboards (DOCX/TXT).
`lab_diagrams/`	Directory	Mermaid/PNG diagrams (network, timeline).

File formats & names: Use descriptive, lowercase names. E.g., `vsftpd_backdoor_exploit.sh`, `nmap_scan.png`, `report_findings_section.docx`. The main report can be .docx or .pdf (both are acceptable), but supply it in the repo. All code or scripts as `.sh`, `.py`, etc. A `README.md` (root) and `README.md` inside major folders can guide readers.

Commit history: Show progression: e.g.

- *"Initial commit: lab setup & topology diagram"*
- *"Add Nmap enumeration steps and output screenshots"*
- *"Exploit VSFTPD 2.3.4 backdoor – Metasploit module"*
- *"Update report draft and remediation recommendations"*

- *"Add video script and recording checklist"*.
  Use feature branches (e.g., `exploit-vsftpd`, `report`, `video-script`) merged into `main`. Each commit should have a clear message referencing the content (like `[Finding 1]`, `[Doc]`, `[Demo]`).

Detailed Report Outline

The report follows industry standards【18†L21-L27】【20†L147-L156】. It should be **thorough, evidence-backed, and professional**. A suggested template (with evidence numbering) is:

1. **Executive Summary (1–2 pages):**

2. **Audience:** C-level and non-technical stakeholders【20†L156-L164】.

3. **Content:** Scope of test, overall risk posture, number & severity of findings, and whether critical assets were compromised. E.g., "This assessment of Metasploitable2 (authorized lab VM) identified 4 critical vulnerabilities leading to root compromise. Key recommendations are to apply patches and network segmentation." Avoid jargon; include date range, overall risk rating【20†L158-L166】.

4. **Scope & Assumptions:**

5. **In-scope:** e.g. `192.168.56.100-105`, web application on port 80, etc.

6. **Out-of-scope:** e.g. no physical attacks, no social engineering.
7. **Rules of Engagement:** E.g. testing window, tools allowed, interruption policy.
8. Cite frameworks like NIST SP 800-115 for methodology planning【20†L170-L178】.

9. **Methodology:**

10. **Approach:** E.g. gray-box test, using reconnaissance, scanning, exploitation, and post-exploitation phases (PTES model).

11. **Tools:** List tools and versions (Nmap, Metasploit, Burp, etc.) for reproducibility【20†L180-L185】. Include a pentesting checklist mapped to the methodology.
12. **Network Diagram:** Include the lab topology (Mermaid diagram above) and explain it.

13. **Findings & Evidence (Technical Details):**
    For each vulnerability discovered, include:

14. **Title & Severity:** (e.g. *"CVE-XXXX-XXXX: VSFTPD 2.3.4 Backdoor – Critical"*).

15. **Description:** What is the issue? Where is it (service, port, app)?
16. **Affected Systems:** IPs, applications impacted.
17. **Proof of Concept (PoC):** Exact commands run, output, and **screenshots** that prove exploitation【20†L195-L204】. For example: `msfconsole`, module name, session opened.
18. **Steps to Reproduce:** A bullet list of commands another tester can follow.
19. **Classification:** Map to OWASP Top 10 or CWE (e.g. CWE-89 for SQLi) for tracking.

20. **Impact:** Explain what the attacker gained (e.g. user data, root shell, pivot capabilities).

21. *Example Finding Table:*

Finding	Severity	Affected Host	CVSS (v3)	Description
VSFTPD 2.3.4 Backdoor (TCP/21)	Critical	Metasploitable2 (10.0.0.5)	9.8 (Confirmed by exploit)	Embedded backdoor gives root shell (port 6200 spawned).
Tomcat Manager Upload (TCP/8180)	High	Metasploitable2	8.6	Unauthenticated WAR upload allowed (destroys integrity).

Each finding should have **screenshots**: e.g. Nmap port scan image, Metasploit output, Burp request/response. Caption each figure (e.g. *"Figure X: Nmap discovery of vsftpd on port 21"*). Evidence quality is crucial: without screenshots or log dumps, findings are just claims【20†L209-L214】. 5. **Risk and Prioritization:**

- Use CVSS base scores for a baseline【20†L216-L225】, but adjust based on context. E.g., "FTP (port 21) is internet-facing, so a backdoor there is extremely high risk". Discuss **blast radius** and exploit maturity.
- Possibly include a table of findings with risk and CVSS, noting why context raises/lowers priority (as Wiz suggests, raw CVSS can be insufficient【20†L218-L227】).

- **Remediation Recommendations:**
  For each issue, provide at least one fix (patch, config change, compensating control)【20†L241-L249】. For instance:

- *VSFTPD:* Upgrade to a patched version or disable the backdoor feature (the backdoor was introduced in v2.3.4)【8†L274-L283】.

- *Tomcat:* Remove or secure the Manager app, enforce strong authentication, or upgrade Tomcat to a fixed version.
- Include general advice: enforce least privilege (do not run services as root), network segmentation, and regular patch management.
  Use authoritative sources for guidance: e.g., OWASP "Defense in Depth" (https://owasp.org/www-project-cheat-sheets/cheatsheets/Vulnerability_Disclosure_Programs_Cheat_Sheet.html) or vendor release notes. If possible, cite official advisories or CVE descriptions.
- **Post-Exploitation and Impact:**
  Summarize what we did after gaining access. E.g., "After obtaining a shell, we dumped the `/etc/passwd` and `shadow` files, confirming we could add a new user or escalate privileges." Include examples of commands (`whoami`, `uname -a`) and results.
  Also note any "discovered evidence" of sensitive data (if part of scope). Emphasize that all data is fake (e.g. dummy personal data) to avoid actual privacy concerns.
- **Conclusion:**
  Reiterate the overall security posture and main fixes needed. Reinforce that this was a *practice lab* scenario.

- **Appendix:**

- Raw outputs or logs (Nmap scans, `strace` logs, full tool outputs) referenced in findings.

- Full evidence (screenshots), perhaps with filenames matching those in the repo.
- Any code (custom scripts) included as text or attachments.

Throughout, use tables and bullet lists for clarity. Keep paragraphs short and focused. The report should cite any external sources (like OWASP cheat sheets) when recommending defences. For example, for SQL injection we would note "Use parameterized queries or prepared statements【11†L279-L288】".

Example Exploit Walkthroughs

Below are two representative lab exploits, with exact commands, expected outputs, and guidance on what to screenshot.

1. Exploiting VSFTPD 2.3.4 Backdoor (Metasploitable2)

Target: Metasploitable2 (FTP service v2.3.4).
Vulnerability: VSFTPD 2.3.4 contained a backdoor in a malicious release. Connecting with a special user triggers a shell【8†L288-L296】.

Steps: 1. **Reconnaissance:** On Kali, run `nmap -sV 10.0.0.5` to find open ports. Screenshot the Nmap output highlighting `21/tcp open ftp vsftpd 2.3.4`. (This shows the vulnerable service.)
2. **Metasploit:** Launch `msfconsole`. Use `search vsftpd` and then:

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOST 10.0.0.5
exploit
```

Expected: Metasploit will connect and open a shell. You should see a message like `Command shell session X opened (10.0.0.5:6200)`.
3. **Post-exploit:** In the new shell, run `whoami` (should be `root`) and `id`. Screenshot these commands and outputs (e.g., a terminal showing `root@metasploitable:/# whoami`).
4. **Evidence:** Capture the Metasploit console window (session opened) and the root shell prompt. These images become figures in the report. For example: *Figure: "Metasploit gained root shell on Metasploitable2 via VSFTPD backdoor."*

Mitigation: Update or remove VSFTPD 2.3.4. The Rapid7 guide notes this backdoor provides immediate root【8†L288-L296】. The vendor released newer versions without the backdoor. Also, network firewalls can block port 6200 or restrict FTP access.

2. Exploiting SQL Injection on a Web App

Target: A vulnerable web application (e.g. DVWA, Mutillidae) running on Metasploitable.
Vulnerability: SQL Injection in a search or login form. (OWASP Top 10: SQLi【11†L248-L257】.)
Steps:
1. **Discover the form:** Navigate to `http://10.0.0.5/dvwa` (or the target URL). Identify a form field (e.g. an input named `id`).
2. **Test injection:** In the browser (or with curl), submit `id=1' OR '1'='1` or use a proxy tool. We expect the application to return data as if authenticated.
3. **Validate:** Screenshot the response page showing data that shouldn't be visible. Also capture Burp request/response that includes the injected payload. *Figure: "SQL injection via ' OR '1'='1 reveals user data."*
4. **Automation:** Show using `sqlmap`: e.g. `sqlmap -u "http://10.0.0.5/vulnerable.php?id=1" --batch --dump`. Screenshot the terminal retrieving data from the `users` table.
5. **Evidence:** Capture the SQLmap output and browser. Label screenshots (e.g., *"Proof-of-concept of SQL injection retrieving admin password"*).

Mitigation: Follow OWASP guidance: use **prepared statements/parameterized queries**【11†L279-L288】, or ORM tools. Validate/whitelist input. For existing vulnerability, apply a patch or input filtering. (For dynamic languages, frameworks often have built-in escaping; ensure it's enabled.) Advice like *"Do not build SQL queries via string concatenation"* comes directly from OWASP【11†L248-L257】.

Screenshots & What to Capture

For each exploit, include:

- **Setup Screens:** Show Kali's desktop with terminal (optional) and target's screen (or indicator) to contextualize. For instance, a screenshot with both VM windows.
- **Command Outputs:** Terminal windows showing exact commands and results (`nmap`, `msfconsole`, `mysql`, etc.). Ensure text is legible. Use full-screen or copy-paste with syntax highlighting in report.
- **Application Screens:** Browser windows showing exploited web pages.
- **Network Diagrams:** If needed, a small diagram of attack flow.
- **Remediation Verification (optional):** After fixing, show that service is no longer vulnerable (e.g., `nmap` no longer shows v2.3.4, or injection is sanitized).

Mitigation and Hardening

Based on findings, we recommend **layered security improvements**:

- **Patch Management:** Immediately update vulnerable software. For example, remove the VSFTPD 2.3.4 backdoor by upgrading to VSFTPD 3.x. Keep the Linux OS updated.
- **Least Privilege:** Ensure services run with minimal privileges. The FTP service should not run as root【11†L279-L288】.
- **Network Controls:** Use VLANs or firewalls to restrict access. For a web server, close unnecessary ports (e.g. disable Telnet/FTP if not needed). Rapid7 advises that Metasploitable's interfaces "should never be exposed to a hostile network"【8†L248-L257】 – emulate this in production by isolating critical services.

- **Secure Coding:** Follow OWASP guidelines. For SQL injection, use **parameterized queries**【11†L279-L288】 or stored procedures, and reject unvalidated input. For XSS (if applicable), apply proper output encoding or sanitization【14†L279-L288】.
- **Configuration:** Remove default credentials (Metasploitable's `msfadmin` account is for training only). Change all default passwords.
- **Monitoring & Logging:** Enable logging on all services. Use intrusion detection for unusual logins or file changes. Record all test outputs (as done above) for audit.
- **Firewall & IDS:** On Kali or the hypervisor, use `ufw` or iptables to allow only needed connections. Check `ufw status` and disable unneeded services【15†】. Consider host-based intrusion detection.
- **Vendor Advisories:** Adhere to vendor security bulletins. For example, if Apache Tomcat has a known CVE for the Manager app, apply the fixed version or remove the web apps entirely. (Refer to Apache's official announcement for each CVE.)

These measures follow best practices from OWASP and NIST (e.g., [NIST SP 800-53] roles on least privilege) and should be documented in the report's remediation section【20†L241-L249】.

GitHub README Template

A `README.md` at the repo root should guide users. Example outline:

```
# Lab 5: Penetration Testing Exercise

## Overview
This repository contains the deliverables for a simulated penetration test
between Kali Linux (attacker) and Metasploitable2 (target). All activity was
confined to a private lab network (no internet). The purpose is educational.

## Lab Topology
- Attacker (Kali): 192.168.56.102
- Target (Metasploitable2): 192.168.56.101
[Insert network diagram image or ASCII art here]

## Prerequisites
- VirtualBox or VMware with host-only network.
- Kali Linux (2026.1 or later) with required tools.
- Metasploitable2 VM (Ubuntu 8.04) (download from Rapid7).
- SSH or console access to Kali.

## How to Reproduce
1. Start Kali and Metasploitable2 VMs on the same host-only network.
2. Verify connectivity: `ping 192.168.56.101`.
3. Follow the steps in `report/penetration_report.docx` (or `report.pdf`) for
enumeration and exploitation.
4. All screenshots and code are in `evidence/` (see Figure captions in the
report).
```

```
## Repository Structure
- `report/` – Final written report (DOCX/PDF).
- `scripts/` – Any scripts used (e.g. `exploit_vsftpd.sh`).
- `evidence/screenshots/` – Image files showing terminal outputs and web pages.
- `demo/` – Video script and storyboard text files.
- `lab_diagrams/` – Network and timeline diagrams (mermaid).

## Reporting Issues
This is a student project repo. Contributions or corrections (pull requests) are
welcome.

## Authors
- [Your Name] ([student ID or handle])
- Based on [Rapid7 Metasploitable documentation]【8†L248-L257】 and OWASP
guidelines【11†L279-L288】【14†L279-L288】.
```

10-Minute Demo Video Script & Checklist

Goal: Live demo of one exploit (e.g. the VSFTPD backdoor) with commentary. The script below is a timeline with narration and on-screen actions.

Time	Speaker / Action	Narration (Spoken)
0:00	*Scene:* Kali desktop ready, terminal open. Show topology diagram briefly.	*"Hello, I'm [Name]. Today I'll demonstrate a penetration test in a safe lab. We have a Kali attacker VM and a Metasploitable2 target VM on a private network."* (5s)
0:30	Show Kali `ifconfig` and Metasploitable IP. Check connectivity.	*"Metasploitable2 is at 192.168.56.101. Kali is 192.168.56.102. Let's verify connectivity."* (ping)
0:50	Open Firefox on Kali, access target's HTTP page (if any).	*"We begin with reconnaissance. I'll run Nmap from Kali to identify open ports on the target."* (shown)
1:10	Execute `nmap -sV 192.168.56.101`. Point out ftp port 21 and version.	*"Nmap scan shows vsftpd 2.3.4 on port 21 – a known backdoor version.【8†L288-L296】"*
1:30	Discuss vulnerability.	*"This version's backdoor allows remote root shell access. We'll exploit it using Metasploit."*
1:50	Switch to terminal. Type `msfconsole`.	*"Launching msfconsole."* (enter)
2:00	In msfconsole: `search vsftpd` and `use exploit/unix/ftp/vsftpd_234_backdoor`.	*"Found the vsftpd_234_backdoor module. Using it now."*
2:10	`set RHOST 192.168.56.101`; `exploit` (hit Enter).	*"Setting target IP and running exploit."*

Time	Speaker / Action	Narration (Spoken)
2:20	**Screenshot:** Metasploit shows `session opened (root@...)`. Switch to shell.	*"We have a session! Let's check user."* (types `whoami`)
2:30	Show `root`. Perform `uname -a`, `ls /root`.	*"We're root on Metasploitable. Here's the system info and root directory."*
2:50	End exploit demo, switch to web browser or slide with summary.	*"This demonstrates a successful exploit in a lab environment, without harming any real system."*
3:00	**Media Insert:** Diagram of attack flow or Metasploit meterpreter screenshot.	(no voice, just image and annotation)
3:10	Talk about remediation: show report or bullet list.	*"As recommended in our report, we would immediately update the FTP service or remove it. Also disable unnecessary services on real servers."*
3:40	Conclusion and advice.	*"In conclusion, always confirm you're on the intended domain/IP before logging in. Use encrypted, authenticated protocols and keep software up-to-date."*
4:00	(Outro credits)	*"Thank you."*

Checklist for Recording:

- **Captions:** Ensure video has title/captions (lab name, date).
- **Screenshots Needed:**
- Nmap output (showing vsftpd 2.3.4).
- Metasploit console with exploit commands and *"Session opened"*.
- Root shell (`whoami`, `uname -a`).
- Lab topology or network diagram.
- (Optional) Browser with target site or searchsploit output.
  Each screenshot image should have a brief caption (e.g., *"Figure X: Found vulnerable vsftpd service on target."*).

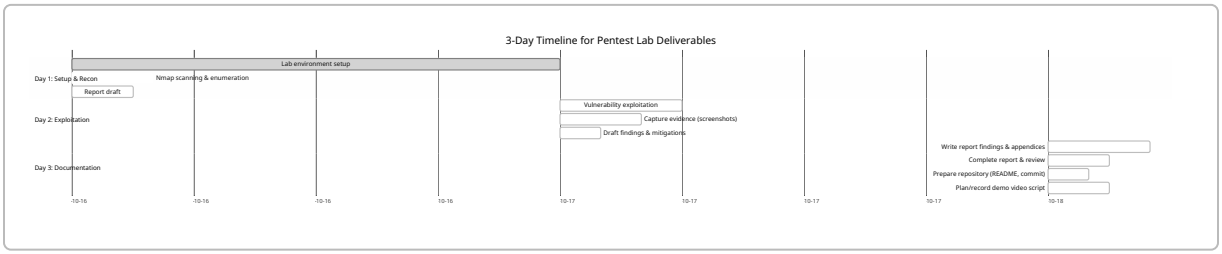
- **Recording:**

- Use screen recording software on Kali (with both Kali and VirtualBox windows visible if possible).
- Narration paced clearly; highlight cursor or use zoom for key commands.
- Do **not** record sensitive info (no real credentials to hide; use dummy text).

The script above is approximate. Ensure total video ≈10 minutes. It can skip some steps (or accelerate) to fit time, focusing on critical actions. Use bullet points or subtitles on-screen for key commands.

Timeline (3-Day Plan)

We recommend a brief timeline to manage the workload:



Legend: Each block shows tasks by day. Adjust dates as needed. Ensure peer review before final submission.

References

Key authoritative sources used:

- OWASP Cheat Sheets for injection mitigation【11†L279-L288】【14†L279-L288】.
- Rapid7's Metasploitable2 guide (describing services and setup)【8†L248-L257】.
- Wiz "Penetration Testing Report" article for report structure【20†L195-L204】【20†L241-L249】.
- NIST SP 800-115 (security test planning) mentioned for scope【20†L170-L178】.
- Pentest report templates (GitHub) for structure examples【24†L223-L225】【26†L369-L378】.
- Kubesimplify lab walkthrough as a demonstration model【5†L86-L89】【5†L108-L113】.

Each deliverable (report, repo, video) aligns with these best practices to ensure the lab exercise is **educational, reproducible, and safe**.
